

› Free Software Isn't Gratis

Why companies should treat Open Source as part of their infrastructure

Christopher Tineo

SRE @ Palantir Technologies



Christopher Tineo

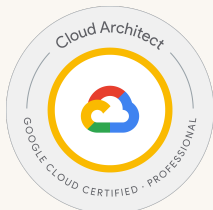
SRE · Palantir Technologies



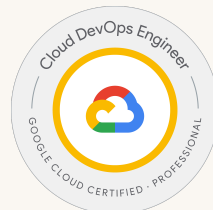
CNCF
Ambassador



Kubestronaut



GCP Cloud
Architect



GCP Cloud
DevOps



CKS

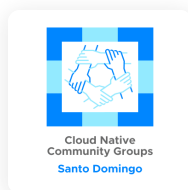


MCPA

COMMUNITY



UPSTREAM



ORGANIZER



Kubernetes SIG Contributor Experience · **Member**

The five acts

01

Problem

The "free" in free software has a price someone pays.

02

Examples

What it looks like when the bill comes due.

03

Cost

To companies, to maintainers, to the ecosystem.

04

Solution

Treat open source like the infrastructure it is.

05

Action

What you do on Monday morning.

The Problem

"Free" has a price. Someone always pays it.

Open source is everywhere

98%

OF 947 AUDITED COMMERCIAL
CODEBASES CONTAIN OPEN SOURCE

\$8.8T

what companies would pay to
replace the OSS they use

5%

of OSS developers create 96% of
that value

🎓 Harvard Business School • WP 24-038

"We estimate the supply-side value of widely-used OSS is \$4.15 billion, but that the demand-side value is much larger at \$8.8 trillion."

Hoffmann, Nagle & Zhou • "The Value of Open Source Software" • Jan 2024

Free software $\neq$ Open source

Two overlapping but distinct philosophies. Same code, different why.

FREE SOFTWARE

A movement

- › User freedom as the goal
- › **FSF** · 1985 · Richard Stallman
- › Four freedoms (run, study, modify, share)
- › License ethos: **copyleft**

OPEN SOURCE

A methodology

- › Practical benefits as the goal
- › **OSI** · 1998 · Raymond & Perens
- › 10 Open Source Definition criteria
- › License ethos: **permissive**

$\neq$

*Most projects are **both**. The difference is the why, not the what.*

"Free" as in beer vs "free" as in speech



Richard Stallman, founder of the GNU Project and the Free Software Foundation. His framing of "free software" — meaning freedom, not price — gave us this wordplay.

Stallman chose **"free"** to mean freedom (speech), not price (beer).

The English language has only one word for both, causing 40 years of etymological confusion.

This talk is about the gap between them — and who pays for it.

The Examples

What it looks like when the bill comes due.

What is ingress-nginx?



The front door to your Kubernetes cluster.

Routes external traffic into your services.

Maintained by a handful of unpaid SIG Network volunteers.

~60%

of CERN's Kubernetes deployments relied on ingress-nginx as their ingress controller at the end of 2025.

Project `kubernetes/ingress-nginx` · Steward Kubernetes SIG Network

Sources: [CNCF End User TAB, "Ingress NGINX retirement: Experience from end users", Apr 2 2026](#) (CERN: "As of the end of 2025 ~60% of deployments rely on ingress-nginx")

"In 9 years, ingress-nginx had exactly one 'call for maintainers' issue."

It got 10 thank-you comments and 0 volunteers.

The announcement → EOL

Nov 11,
2025

Retirement announced: best-effort maintenance until March 2026, then nothing.

Jan 29,
2026

Steering + Security Response statement: "critical infrastructure for about half of cloud native environments."

Mar 19,
2026

Last release (helm-chart-4.15.1). Repo archived days later. No more fixes, no more CVE patches.

Now

Six months unpatched. Anyone still running it has an internet-facing edge nobody maintains.

~50%

of cloud native environments
depend on it

41%+

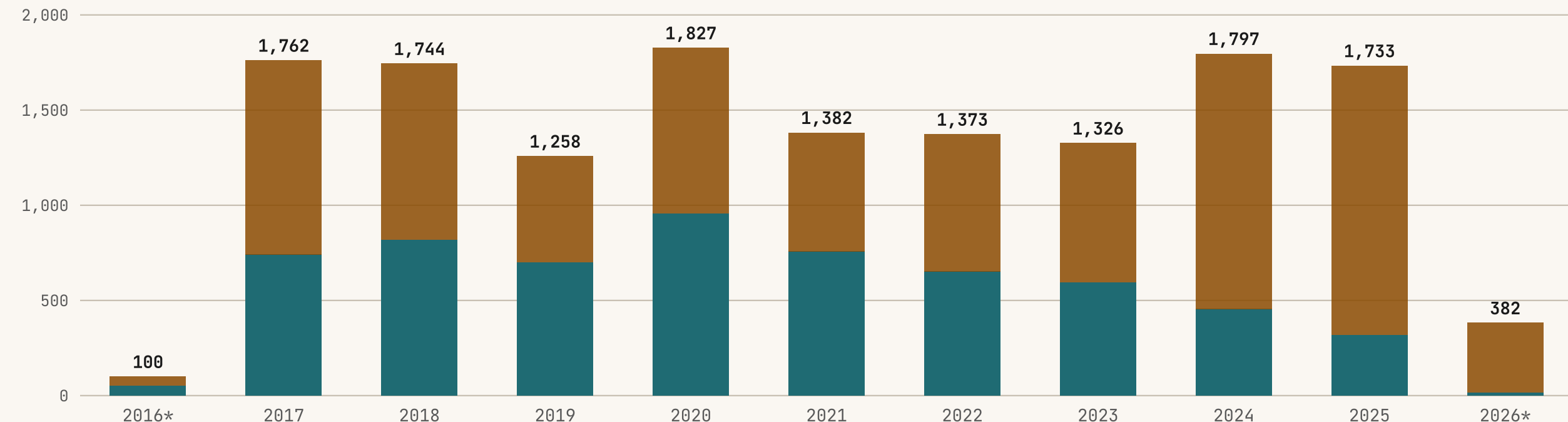
of internet-facing clusters ran it

6,500+

clusters exposed its admission
controller to the internet

10 years of demand on a handful of volunteers

Issues and pull requests opened per year on kubernetes/ingress-nginx



■ issues ■ pull requests * 2016 starts Nov 4 (repo created) · 2026 ends at the March archive

~14.7k

issues + PRs opened, 2016 → 2026

41%+

of internet-facing clusters ran it (Wiz, Mar 2025)

~50%

of cloud native environments (Steering, Jan 2026)

Sources: GitHub search API, repo:kubernetes/ingress-nginx created:<year>, queried Sep 26 2026 · [Wiz Research, Mar 24 2025](#) · [Kubernetes Steering statement, Jan 29 2026](#)

The humans behind the controller

14.7k

issues + PRs over 9 years

8

critical CVEs in 2 years

50+

issues permanently frozen

\$0

compensation for maintenance

› what they actually do (\$0 budget · after hours · on weekends)

Triage & Review · CVE Patching · Release Management · End-User Support

@RIKATZ · DEC 15, 2024 · KUBERNETES/ORG#5305

"I need some time for myself, and I am not really being able to take care of the project and my personal life together :)"

Why it collapsed

THE CVE MANIA

Eight significant CVEs and RCEs in two years — and the maintainers who had to fix them were not being paid to do it.

› 2022 · June

"we're drowning" mailing list
call

› 2024 · May

CVE cascade forces emergency
patches

› 2025 · March

CVE-2025-1974 RCE forces
final EOL

"This is fine." 

The Cost

To companies. To maintainers. And now, the AI flood.



×



25 YEARS · EVERY APPLE OS SINCE 2001

**"We have never worked with Apple,
never received sponsorship by Apple,
not had them as customers..."**

Daniel Stenberg · curl · Sep 25, 2026

\$0

from the most valuable
company on earth to the tool in
every one of its devices

Cost to companies

50%

"critical infrastructure for about half of cloud native environments." Kubernetes Steering Committee on ingress-nginx.

Zero

direct 1-1 drop-in replacements exist. Every migration requires manual annotation translation.

OFFICIAL STEERING COMMITTEE STATEMENT

"None of the available alternatives are direct drop-in replacements. This will require planning and engineering time. Half of you will be affected."

Translate hundreds of custom Nginx annotations. Unplanned migrations are measured in **engineer-months** of lost roadmap velocity.

Cost to maintainers

60%

of open source maintainers are unpaid for their work

"Nobody has been paying anyone to work on this software for some time, it has been entirely volunteer driven and they've been overwhelmed."

[@BenTheElder](#) · [Kubernetes Steering Committee](#) · Jan 21, 2026

The cost is the most expensive line item in this talk: time, health, and career impact. A salary or protected time would have changed the math.

The CVE cascade turned volunteer contributions into an unpaid second job with constant security liability.

AI didn't shrink the work. It multiplied the inbox.



daniel.haxx.se · "curl summer of bliss" · Jun 15, 2026

🔗 Daniel Stenberg · curl

"We have been under a huge pressure for the last four months or so. Now we need some rest. We do not expect this deluge to be over."

No vulnerability reports accepted Jul 1 – Aug 3, 2026 · paid support contracts still served

25M → 90M+

merged pull requests per month on GitHub, Jan 2023 → Jun 2026 (~3.6x)

2x

curl's security-report rate vs. 2025, "which already was more than double from previous years"

~2%

of git.kernel.org's ~6M daily requests are legitimate. The rest are scrapers.

In their own words

🗨 @bagder · curl maintainer · Aug 10, 2026

"Reminder: we communicate as humans here. You should describe the change, not the AI."

[curl/curl#22531](#)

🗨 @sirosen · Jan 31, 2026

"Just today I had to batch-close several AI generated PRs which were all submitted around the same time."

[github community discussion #185387](#)

🗨 @chadlwilson · Feb 3, 2026

"...after spending significant time reviewing it and making multiple comments to eventually conclude that much of it was "plausible nonsense" which had never actually been validated."

[github community discussion #185387](#)

🗨 @rikatz · ingress-nginx maintainer · Dec 15, 2024

"I need some time for myself, and I am not really being able to take care of the project and my personal life together :)"

[kubernetes/org#5305](#)

🗨 @BenTheElder · Kubernetes Steering Committee · Jan 21, 2026

"Building trust for owning critical software takes time, we needed that to happen years ago during the earlier pleas for support."

[kubernetes/ingress-nginx#14178](#)

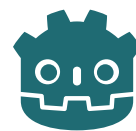
So maintainers are closing the door

Summer 2026, in policy form.



GITHUB • JUN 17 → AUG 6

Caps on open PRs from users without write access. AI-agent PRs count toward the cap. Now settable per org.



GODOT • JUN 30

"This reviewer shortage was already a problem, but it was one that we successfully ignored. We can no longer ignore it."



GCC • JUL 29

"decline any legally significant contributions which include LLM-generated content" (~15+ lines).



CODEBERG • JUL 22

Members vote 358–144 to stop hosting mostly LLM-generated projects.

AI finds bugs faster than volunteers can fix them



Anthropic · Project Glasswing

"...some have even asked us to slow down our rate of our disclosures because they need more time to design patches."

75 of the 530 high/critical bugs reported to OSS projects patched at the time of writing

BLACK DUCK OSSRA 2026

Mean vulnerabilities per codebase up **107%** to **581**.
87% of codebases contain at least one.

MOZILLA · WITH A PAID TEAM

423 Firefox security bugs fixed in April 2026, **271** of them found by an AI pipeline.

PATCH THE PLANET · JUN 22

"a firehose of security findings, and already-stretched maintainers must sift through all of it"

One maintainer's token is your production

2026's supply-chain attacks went through people, not code.



MAR 19, 2026

trivy-action: attackers force-push 76 of 77 version tags to credential-stealing malware. A security scanner, turned into the attack.



JUN 1, 2026

Red Hat: 32 npm packages compromised through a GitHub account "compromised via a VS code extension containing malware".



AUG 4, 2026

ChainDrop worm: 400+ npm packages across unrelated publishers (keyv, cache-manager...) via stolen maintainer credentials.

SEP 18, 2026

npm responds: stage-only tokens and staged publishing with malware scans. Every maintainer now has migration homework.

The Solution

Stop calling it free. Start treating it like infrastructure.

Open source is critical infrastructure

If open source is in 98% of codebases, dependencies are your infrastructure.

And we already know how to treat critical infrastructure:

MONITOR

Watch for advisories, EOL announcements, maintainer health signals.

SET SLOS

Define what "healthy" means for each critical dependency.

STAFF IT

Assign owners. Budget time. Treat maintainer relationships as a critical asset.

The industry just said it out loud



We're In: Enterprise Commitment to Sustainable Package Registries

arm		
		
		
		

openssf.org · "We're In: Enterprise Commitment to Sustainable P..."

12 signers commit to pay registry fees based on enterprise use, as a business investment, while keeping access free for individuals and small orgs. Covers PyPI, npm, Maven Central, crates.io, RubyGems, NuGet, Open VSX, Packagist.

 OpenSSF · Sep 16, 2026

"...the heroic efforts of small teams, often just two or three people."

1.8 million malicious packages needing human takedown "so far in 2026"

 Brian Fox · Sonatype / Maven Central · Jun 16, 2026

"But open does not mean infinite. And free does not mean costless."

Publishing limits + paid "Publisher Pro" tier for commercial scale · enforced Oct 1, 2026

Small money, measurable results



GITHUB SECURE OSS FUND

\$10K × 50

projects in session 4 (Aug 13). Across all sessions: \$1.88M, 188 projects, **533 new CVEs** found and disclosed.



ALPHA-OMEGA • OPENSSEF

\$12.5M

in grants (Mar 17) from Anthropic, AWS, GitHub, Google, Google DeepMind, Microsoft and OpenAI, for maintainers hit by AI-found bugs.



LINUX FOUNDATION • FEB 24

2–5× ROI

from active contribution. Private forks cost **\$258K per release cycle** (5,160 labor hours).



EU Cyber Resilience Act: since Sep 11, 2026 manufacturers must report actively exploited vulnerabilities (24h warning, 72h notification). The legal duty sits with whoever ships the OSS.

What could I do?

01 · DISCOVER

Discover

What are you actually depending on? Generate a complete SBOM. Know your transitive graph.

02 · ASSESS

Assess

For each critical dependency: how many maintainers? Who funds it? Is there a **lottery factor** of one?

03 · FUND

Fund

Registry fees, GitHub Sponsors, the Open Source Pledge (\$2,000 per dev per year), Alpha-Omega, foundation dues. Whatever works.

04 · CONTRIBUTE

Contribute

Time, code, reviews, documentation, security disclosures. The most valuable currency isn't money; it's attention.

The build-vs-buy equation has flipped

AI is driving down development costs,
flipping the build-vs-buy equation.
Traditional SaaS margins are eroding.

~\$1T

software market value lost in
seven days (Feb 2026)

+10%

projected US software developer
jobs, 2025–35 (BLS)

OSS IS THE ENGINE

We build on open source, and now we must pay
our share by contributing fixes upstream.

CASE STUDY · PREVIOUS ROLE AT GAME PLAN TECH

Added GCS Workload Identity support to Percona
MongoDB Operator for a federal compliance
workload.

Rather than maintaining a private fork, contributing
upstream solved it for us and the community.

The Action

What you do on Monday morning.

What you do on Monday



LEADERS & SRE TEAMS

Before adding a new dependency to your tech stack:

"If the core maintainer for this project won the lottery, what's the worst thing that could happen to your project?"



INDIVIDUAL CONTRIBUTORS

Have you ever thought, "Ugh, this project is great but if it had this X feature it would fit my needs perfectly"?

Open a Github Issue and contribute back!

Tagging & tracking with gh / glab

GITHUB CLI (GH)

```
# Loop all repos & fetch transitives (Free)
$ for repo in $(gh repo list --limit 100 \
  --json nameWithOwner -q '.[].nameWithOwner'); do
  gh api repos/$repo/contents/package-lock.json \
    -H "Accept: application/vnd.github.raw" | \
    jq -r '.packages | keys[] | select(. ≠ "")'
done

# Bulk check Lottery Factor (>10 contributors)
$ for repo in $(gh repo list --limit 100 \
  --json nameWithOwner -q '.[].nameWithOwner'); do
  gh api repos/$repo/contributors \
    --jq '.[[] | select(.contributions > 10)] | length'
done

# Bulk Tag / Star dependency repos
$ for repo in $deps; do
  gh repo edit $repo --add-topic "critical-dep"
  gh api -X PUT user/starred/$repo
done
```

GITLAB CLI (GLAB)

```
# Loop all projects & fetch transitives (Free)
$ for repo in $(glab repo list -F json | \
  jq -r '.[].path_with_namespace'); do
  enc="${repo//\//%2F}"
  glab api projects/$enc/repository/files/package-lock.json/raw
| \
  jq -r '.packages | keys[] | select(. ≠ "")'
done

# Bulk check Lottery Factor (>10 commits)
$ for repo in $(glab repo list -F json | \
  jq -r '.[].path_with_namespace'); do
  enc="${repo//\//%2F}"
  glab api projects/$enc/repository/contributors | \
  jq 'map(select(.commits > 10)) | length'
done

# Bulk Tag / Star GitLab projects
$ for repo in $deps; do
  enc="${repo//\//%2F}"
  glab api -X PUT projects/$enc -F "topics=critical-dep"
  glab api -X POST projects/$enc/star
done
```


Automating with OSS Review Toolkit (ORT)

GITHUB ACTION

```
- name: Run ORT Analyzer
  uses: oss-review-toolkit/ort-ci-github-action@v1
  with:
    vcs-url: "https://github.com/TineoC/contributor-site"
    output-dir: "ort-output"
```

GITLAB CI/CD

```
ort_analyzer:
  image: ghcr.io/oss-review-toolkit/ort:latest
  script:
    - ort analyze -i . -o ort-output
```

 Explore compliance tools: [ORT](#) · [Snyk](#) · [GitHub Dependency Graph](#)



REPORT: GITHUB.COM/TINEOC

This is fine.

It's only fine if we pay for it.

 Thank you · Christopher Tineo · Palantir Technologies

kubernetes.io/blog/2026/01/29/ingress-nginx-statement · gnu.org/philosophy/free-sw

Let's keep in touch



 **LinkedIn**

linkedin.com/in/christopher-tineo



 **Slides**

tineoc.github.io/talks